

A decorative background featuring a network diagram. It consists of numerous nodes, represented by small circles, connected by thin lines. Some nodes are solid blue, while others are hollow blue circles. The network is more densely packed on the left and right sides of the slide, with the central area being mostly white space containing the title.

Crypto Best Practices

Encryption

- AES:
 - $\text{AES_Encrypt}(m, 0^{128})$
 - $\text{AES_Encrypt}(m, (01)^{64})$

Is this fine?

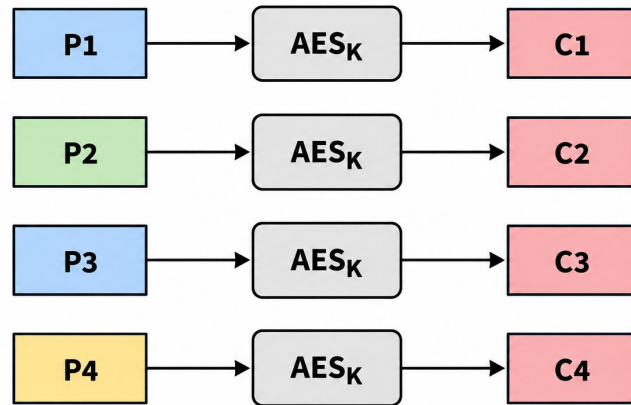
Encryption

- RSA:
 - $p=3, q=5$

Is this fine?

Encryption

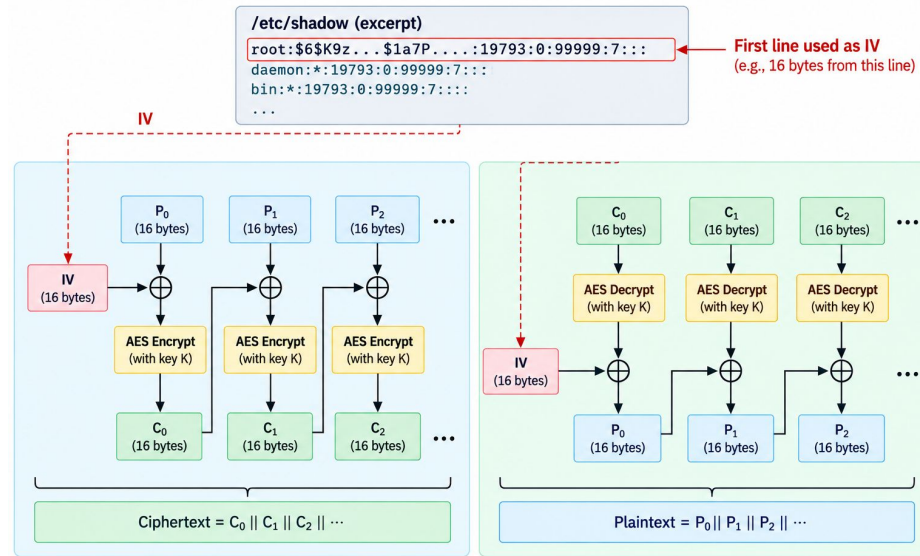
- AES:



Is this fine?

Encryption

- AES:



Is this fine?

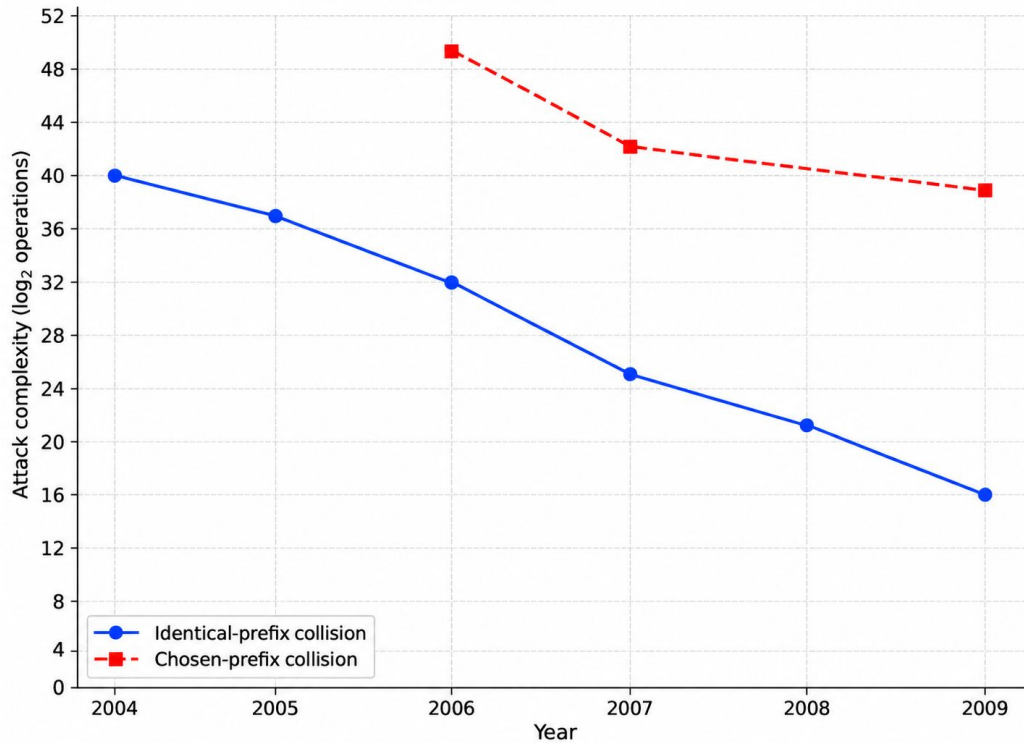
Encryption Best Practices

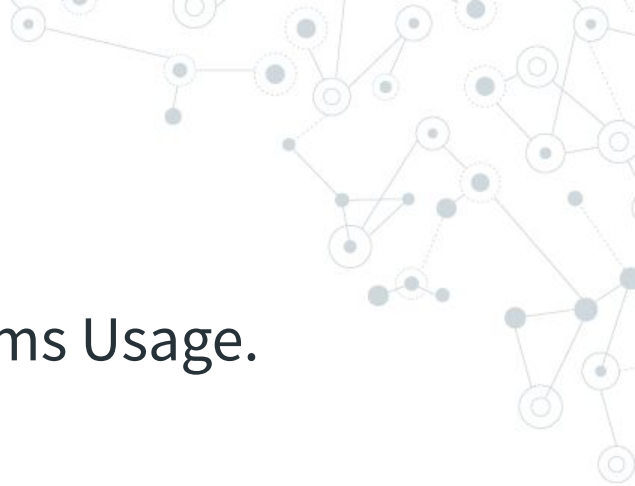
- Use strong cryptographic algorithms.
- Use Strong/Randomly generated keys.
- Always use random values when arbitrary values are needed.
- Ensure you are using secure random number generators.

Threats Against Hashing

- Finding preimage.
- Finding collisions.

Attacks against MD5





Standards

NIST-SP800-131A: Cryptographic Algorithms Usage.

NIST-SP800-57: How to maintain keys.

NIST Approved Symmetric Encryption Algorithms

Algorithm	Status
Two-key TDEA Encryption	Disallowed
Two-key TDEA Decryption	Legacy use
Three-key TDEA Encryption	Deprecated through 2023 Disallowed after 2023
Three-key TDEA Decryption	Legacy use
SKIPJACK Encryption	Disallowed
SKIPJACK Decryption	Legacy use
AES-128 Encryption and Decryption	Acceptable
AES-192 Encryption and Decryption	Acceptable
AES-256 Encryption and Decryption	Acceptable

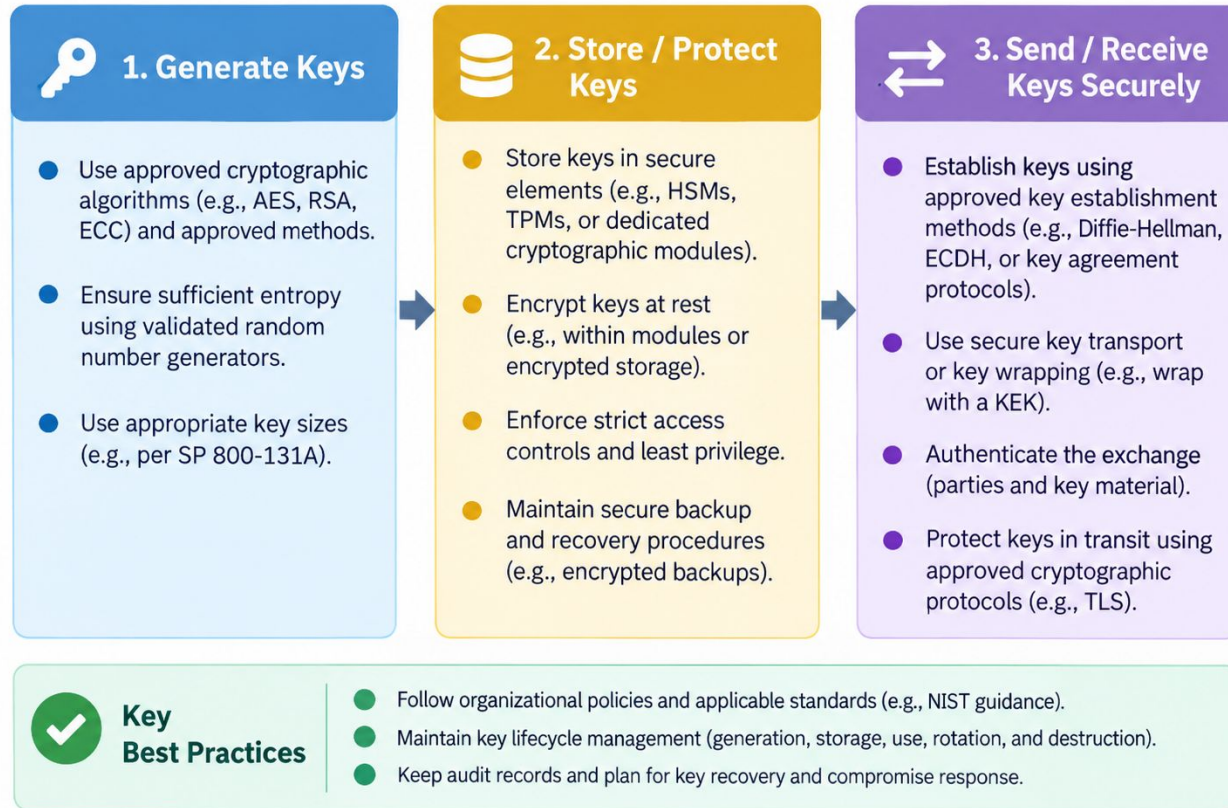
NIST Approved Public Key Encryption Algorithms

Digital Signature Process	Domain Parameters	Status
Digital Signature Generation	< 112 bits of security strength: DSA: $(L, N) \neq (2048, 224), (2048, 256)$ or $(3072, 256)$ ECDSA: $\text{len}(n) < 224$ RSA: $\text{len}(n) < 2048$	Disallowed
	≥ 112 bits of security strength: DSA: $(L, N) = (2048, 224), (2048, 256)$ or $(3072, 256)$ ECDSA or EdDSA: $\text{len}(n) \geq 224$ RSA: $\text{len}(n) \geq 2048$	Acceptable
Digital Signature Verification	< 112 bits of security strength: DSA ³² : $((512 \leq L < 2048)$ or $(160 \leq N < 224))$ ECDSA: $160 \leq \text{len}(n) < 224$ RSA: $1024 \leq \text{len}(n) < 2048$	Legacy use
	≥ 112 bits of security strength: DSA: $(L, N) = (2048, 224), (2048, 256)$ or $(3072, 256)$ ECDSA and EdDSA: $\text{len}(n) \geq 224$ RSA: $\text{len}(n) \geq 2048$	Acceptable

NIST Approved Random Number generators

Algorithm	Status
Hash_DRBG and HMAC_DRBG	Acceptable
CTR_DRBG with three-key TDEA	Deprecated through 2023 Disallowed after 2023
CTR_DRBG with AES-128, AES-192 and AES-256AES-256	Acceptable
DUAL_EC_DRBG	Disallowed
RNGs in FIPS 186-2 ⁴² , ANS X9.31 ⁴³ and ANS X9.62-1998	Disallowed

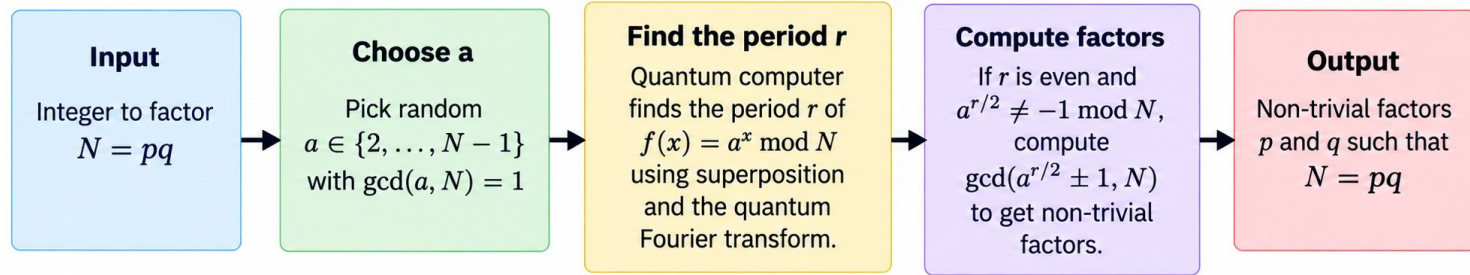
NIST-SP800-57: Key Management



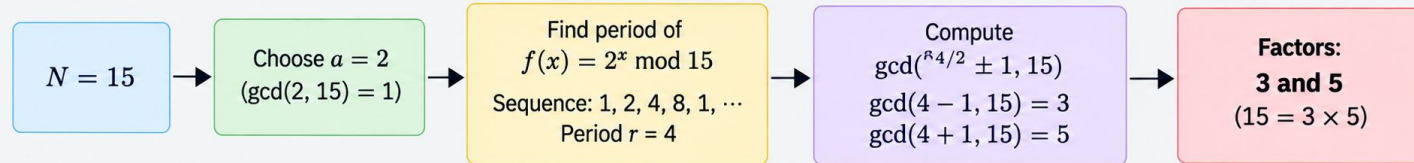
Threats Against Cryptography

- No formal proof -> just hard problems.
 - Machine become powerful: GPUs, Quantum Computers, etc.
- People get smarter.
- LLMs might find solutions (in near future).

Breaking RSA with Shor's (quantum) Algorithm



Example: Factor $N = 15$



Designing your system for crypto agility

```
import hashlib
```

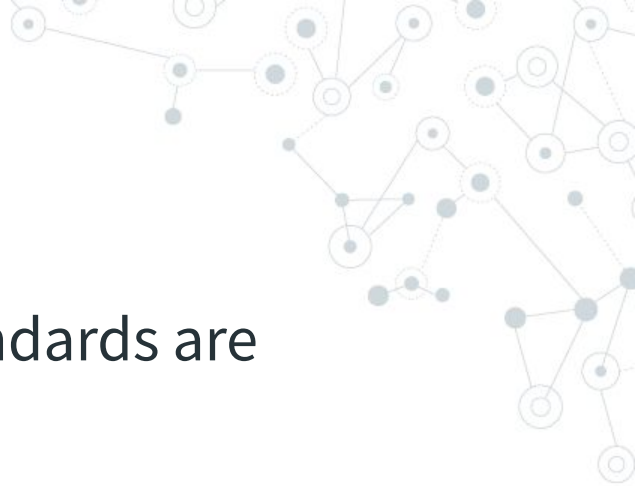
```
def hash_password(password):  
    return hashlib.sha256(password.encode()).hexdigest()
```

```
digest = hash_password(salt+password)
```

Designing your system for crypto agility

```
from cryptography.hazmat.primitives.ciphers.aead import AESGCM
import os

def encrypt(data, key):
    aes = AESGCM(key)
    nonce = os.urandom(12)
    return nonce, aes.encrypt(
        nonce,
        data.encode(),
        None
    )
```



Designing your system for crypto agility

- What do you do when new crypto standards are proposed?



Designing your system for crypto agility

- Organize your software so that it is easy to replace cryptographic algorithms with evolving standards.
- Maintain an abstract library and use it across all your systems.

Cryptoagility

<https://drive.google.com/file/d/1vwxex9ByrhUGIKoKYL3Rf-x2HLJMU0Tv/view?usp=sharing>

Summary

- Use NIST approved algorithms and follow NIST standards for managing keys.
- Use secure random number generators.
- Maintain cryptoagile design of your software.